

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

Cyberattack on Medical and Energy Sector by Lazarus Group

Date of Publication

February 3, 2023

Admiralty Code

A1

TA Number

TA2023062

Summary

Attack Begin: August 2022

Threat Actor: LABYRINTH CHOLLIMA(Lazarus Group, Group 77, Hastati Group, Whois Hacking Team, NewRomanic Cyber Army Team, Zinc, Hidden Cobra, Appleworm, APT-C-26, ATK 3, SectorA01, ITG03, TA404, DEV-0139, Guardians of Peace , Gods Apostles , Gods Disciples)

Attack Countries: Australia, Bangladesh, Belgium, Brazil, Canada, Chile, China, Ecuador, France, Germany, Guatemala, Hong Kong, India, Israel, Japan, Mexico, Netherlands, Philippines, Poland, Russia, South Africa, South Korea, Taiwan, Thailand, UK, USA, Vietnam

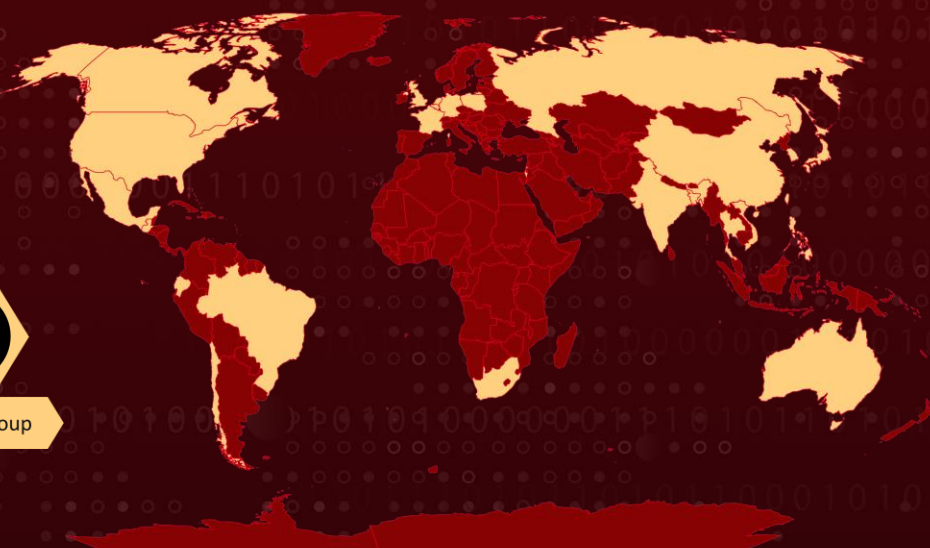
Attack Sector: Aerospace, Defense, Energy, Engineering, Financial, Government, Healthcare, Research, Manufacturing, Media, Shipping and Logistics, Technology and BitCoin

Attack: A cyber-attack conducted by North Korean state-sponsored Lazarus Group targeted public and private sector research organizations, the medical research and energy sector as well as their supply chain for intelligence benefit, exploiting known vulnerabilities in unpatched Zimbra devices and using off-the-shelf webshells, custom binaries, and abusing legitimate Windows and Unix tools.

Attack Regions



Lazarus Group



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

CVE	NAME	PATCH
CVE-2022-27925	Zimbra Collaboration (ZCS) Arbitrary File Upload Vulnerability	
CVE-2022-37042	Zimbra Collaboration (ZCS) Authentication Bypass Vulnerability	
CVE-2021-4034	Red Hat Polkit Out-of- Bounds Read and Write Vulnerability (PwnKit)	
CVE-2021-34527	Windows Print Spooler Remote Code Execution Vulnerability (PrintNightmare)	

Attack Details

#1

During the fourth quarter of 2022, a cyberattack was conducted by a threat actor with high confidence attributed to Lazarus Group. This group targeted public and private sector research organizations, the medical and energy sector, as well as their supply chain. The primary motivation of the attack was assessed to be intelligence collection.

#2

The initial compromise and privilege escalation were carried out through exploiting known vulnerabilities in unpatched Zimbra devices. The threat actor used off-the-shelf webshells and custom binaries, as well as abusing legitimate Windows and Unix tools for living off the land. The actor installed tools for proxying, tunneling, and relaying connections, and the Command-and-Control behavior suggests a small number of C2 servers connecting through multiple relays and endpoints, some of which appeared to be compromised victims themselves.

#3

The attack began with the exploitation of a vulnerable Zimbra mail server in August 2022. The actor used multiple proxy addresses to install commodity webshells and tunnelling/relay software, then exploited a local privilege escalation vulnerabilities(PwnKit & PrintNightmare). A week later, the actor exfiltrated multiple gigabytes of data from the mail server, likely the contents of mailboxes. In October, the actor moved laterally to a vulnerable domain joined Windows XP device and performed further lateral movement, reconnaissance, and deployed multiple custom tools and malware, such as Dtrack and a fresh version of GREASE. The actor relied on multiple off-the-shelf open-source tools and malware.

#4

In November, Cobalt Strike Command and Control beacons were detected, and connections to the actor's infrastructure were seen from other compromised internal servers. Nearly 100GB of data was exfiltrated from the network. The threat actor used a plethora of tools, with a common technique being the use of the Windows temp directory for staging executables. The actor also relied on publicly available remote access tools, such as webshell JspSpy and file browser JspFileBrowser, for persistence.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0003</u> Persistence
<u>TA0004</u> Privilege Escalation	<u>TA0005</u> Defense Evasion	<u>TA0006</u> Credential Access	<u>TA0007</u> Discovery
<u>TA0008</u> Lateral Movement	<u>TA0009</u> Collection	<u>TA0010</u> Exfiltration	<u>TA0011</u> Command and Control
<u>T1016</u> System Network Configuration Discovery	<u>T1018</u> Remote System Discovery	<u>T1021</u> Remote Services	<u>T1021.001</u> Remote Desktop Protocol
<u>T1033</u> System Owner/User Discovery	<u>T1036</u> Masquerading	<u>T1036.005</u> Match Legitimate Name or Location	<u>T1037</u> Boot or Logon Initialization Scripts
<u>T1037.005</u> Startup Items	<u>T1041</u> Exfiltration Over C2 Channel	<u>T1049</u> System Network Connections Discovery	<u>T1053</u> Scheduled Task/Job
<u>T1053.005</u> Scheduled Task	<u>T1057</u> Process Discovery	<u>T1059</u> Command and Scripting Interpreter	<u>T1070</u> Indicator Removal
<u>T1070.004</u> File Deletion	<u>T1070.007</u> Clear Network Connection History and Configurations	<u>T1071</u> Application Layer Protocol	<u>T1071.001</u> Web Protocols
<u>T1074</u> Data Staged	<u>T1082</u> System Information Discovery	<u>T1083</u> File and Directory Discovery	<u>T1087</u> Account Discovery
<u>T1087.002</u> Domain Account	<u>T1090</u> Proxy	<u>T1090.001</u> Internal Proxy	<u>T1090.002</u> External Proxy

T1106 Native API	T1114 Email Collection	T1114.002 Remote Email Collection	T1119 Automated Collection
T1136 Create Account	T1190 Exploit Public-Facing Application	T1505 Server Software Component	T1505.003 Web Shell
T1553 Subvert Trust Controls	T1560 Archive Collected Data	T1569 System Services	T1569.002 Service Execution
T1587 Develop Capabilities	T1587.002 Code Signing Certificates		

✂ Indicator of Compromise (IOCs)

TYPE	VALUE
MD5	b2b36600ce41129fa85a15a7177a61b7cb714000 45b35d1176598be7755a6d56ad8009bb03f3c5b1f7564e93c5b4ec2de6f4f88c80c9691dc068206f 407b934895741a1d3b197e4e3c3d2e3284ebc76a7c40d4ded95f425fa01895f9d4359c9ef250290a cbf1529bf025523532666b0b3d2adbdae657db168b0fb0e478d18a358783429eaed53ca0fe892b378c384b77b7100d6469e5e7b5cfa779dbcbcaa9ab88df19687e6aa8da376e37a8d71421b5b78a2cb4af9bc7ef25755982a00aca920ee7ad51f76c5cc247f12a1976552a1319bd58d813f213d7ebdef4faa489231455dc2e56e2399edd7c10b5522608a7d61156df8e4a5eadac8137c1cbd55145eab654726
SHA256	45b35d1176598be7755a6d56ad8009bb03f3c5b1f7564e93c5b4ec2de6f4f88c80c9691dc068206f
IPV4	104.225.129[.]86 104.225.129[.]103 15.207.207[.]64 209.95.60[.]92 175.45.176[.]27 23.237.32[.]34 193.176.211[.]0/24 146.185.26[.]150 154.6.26[.]2

Patch Links

<https://www.debian.org/lts/security/2022/dla-2899>

<https://gitlab.freedesktop.org/polkit/polkit/-/commit/a2bf5c9c83b6ae46cbd5c779d3055bff81ded683>

<https://oss.oracle.com/pipermail/el-errata/2022-January/012086.html>

<https://www.suse.com/support/update/announcement/2022/suse-su-2022>

<https://portal.msrc.microsoft.com/en-US/security-guidance/advisory/CVE-2021-34527>

<http://www.slackware.com/security/viewer.php?l=slackware-security&y=2022&m=slackware-security.434679>

<https://oss.oracle.com/pipermail/el-errata/2022-January/012084.html>

<https://www.suse.com/support/update/announcement/2022/suse-su-20220189-1/>

<https://www.suse.com/support/update/announcement/2022/suse-su-20220190-1/>

<https://www.debian.org/security/2022/dsa-5059>

<https://oss.oracle.com/pipermail/el-errata/2022-January/012089.html>

https://wiki.zimbra.com/wiki/Security_Center

<https://www.rarlab.com/rar/rarlinux-x32-612.tar.gz>

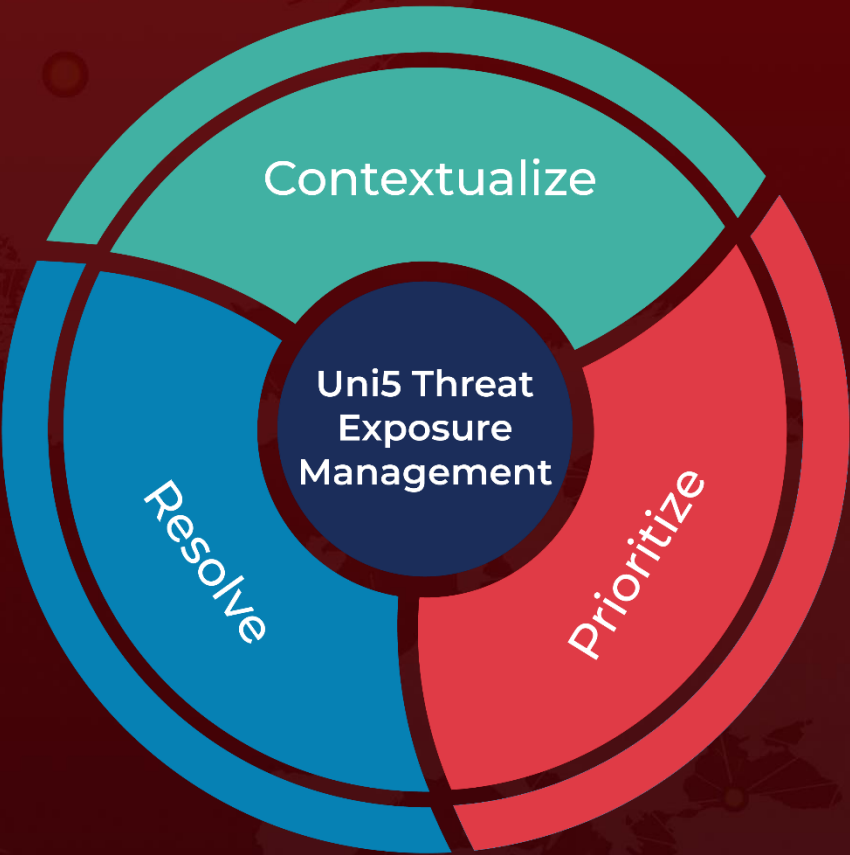
References

<https://labs.withsecure.com/content/dam/labs/docs/WithSecure-Lazarus-No-Pineapple-Threat-Intelligence-Report-2023.pdf>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

February 3, 2023 • 4:00 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com